Critical Infrastructure Security

IY5612 (IY3612/IY4612) — Academic Year 2024/2025 (Unit 6)

Stephen D. Wolthusen
stephen.wolthusen@rhul.ac.uk

Department of Information Security and Communication Technology
Norwegian University of Science and Technology, Norway

and

Department of Information Security
Royal Holloway, University of London, United Kingdom

Unit 6— Introduction to Olympic Games

Contents

Introduction to Olympic Games

Recommended Reading

Introduction

Context and Timeline

Attribution Issues
Stuxnet Attack Mechanisms

Part I

Introduction to Olympic Games

Recommended Reading (1)

- N. Falliere, L. O Murchu, E. Chien:
  W32.Stuxnet Dossier
  Technical Report, Symantec Corporation (Feb. 2011)
- G. McDonald, L. O Murchu, S. Doherty, E. Chien:
  Stuxnet 0.5: The Missing Link
  Technical Report, Symantec Corporation (Feb. 2013)
- A. Matrosov, E. Rodionov, D. Harley, J. Malcho:
  Stuxnet under the Microscope
  eset (2011)

  An alternative analysis of the Stuxnet malware

Recommended Reading (2)

- R. Langner:
  To Kill a Centrifuge: A Technical Analysis of What Stuxnet's Creators Tried to Achieve
  Technical Report, The Langner Group (Nov. 2013)
- D. E. Sanger:
  Confront and Conceal: Obama's Secret Wars and Surprising Use of American Power
  Crown Publishers, New York, NY, USA (2012)

  Some political background on Stuxnet's deployment and also policy (cyber conflict) aspects
- K. Zetter:
  Countdown to Zero Day: Stuxnet and the Launch of the World's First Digital Weapon
  Crown Publishers, New York, NY, USA (2014)

  A journalistic but reasonably detailed perspective of Stuxnet and its discovery

Recommended Reading (3)

- Kaspersky Lab:
  Equation Group: Questions and Answers
  Technical Report, Kaspersky Lab Global Research and Analysis Team (Feb. 2015)
- L. Buttyán (ed.):
  sKyWIper (a.k.a. Flame a.k.a. Flamer): A complex malware for targeted attacks
  Technical Report, Laboratory of Cryptography and System Security (CrySyS), Budapest University of Technology and Economics (May 2012)
- A. Gostev:
  The Flame: Questions and Answers
  Kaspersky Labs (May 2012)
- Kaspersky Lab:
  Gauss: Abnormal Distribution
  Technical Report, Kaspersky Lab Global Research and Analysis Team (Aug. 2012)

Introduction

The main interest in the **Stuxnet** malware for the purposes of this lecture is three-dimensional:

- As a fully executed cyber-physical attack
- As an element of a programme involving intelligence-gathering and attacks
- Highlighting the problems of forensic attribution and analysis

Although Stuxnet dates back to 2009–2010, it is still the most prominent and widely studied example of a cyber-physical attack, and most problems and techniques remain wholly valid

- Stuxnet had a fixed termination date (June 24th, 2012) terminating propagation

Prelude to Stuxnet

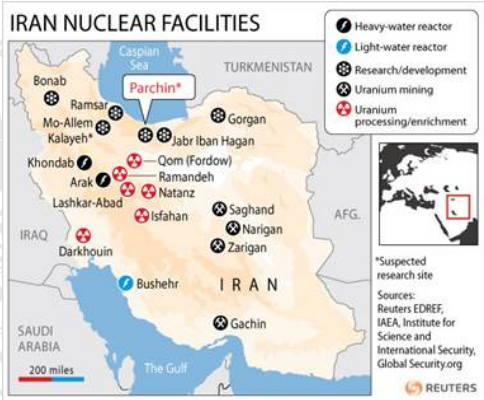
The initial discovery of Stuxnet identified a reasonably sophisticated attack against Microsoft Windows systems

- Only later were targets identified more clearly, requiring careful attribution
- Similarly, the later stages of Stuxnet had to be extracted following the initial identification of the generic malware

Prelude to Stuxnet

The initial discovery of Stuxnet identified a reasonably sophisticated attack against Microsoft Windows systems

- Only later were targets identified more clearly, requiring careful attribution
- Similarly, the later stages of Stuxnet had to be extracted following the initial identification of the generic malware



Suspected and confirmed nuclear facilities in Iran (Uranium enrichment and processing marked in red)

Source: IAEA / Image source: Reuters

Nuclear Capabilities
Uranium Fuel Cycle

Civilian nuclear power stations generally rely on an Uranium-based fuel cycle (others may e.g. use a Thorium cycle) requiring U^{235}. This isotope forms 0.7% of natural Uranium ore, with 99.3% consisting of U^{238}

- The isotopes are chemically identical, but have different numbers of neutrons — only the latter generates sufficient free slow neutrons to sustain a fission chain reaction
- Most reactors require **enrichment** to 3. . . 5% (exceptions include the UK **Magnox** and Canadian **Candu** designs) of U^{235}
- Mass differences between isotopes can be exploited e.g. by running highly precise **gas centrifuges** separating Uranium Hexafluoride (UF_6) at constant speed, first proposed in 1941 (other processes exist, but $>$ 50% of Uranium is enriched by centrifuges as of 2024)

Nuclear Capabilities
Uranium Enrichment

Weapons-grade Uranium for use in nuclear weapons (either as fissile weapons or as part of a multi-stage weapon requires much higher enrichment to $\approx 90\%$ and is called Highly Enriched Uranium (HEU)

- More difficult to obtain, but has no civilian use except for research quantities
- Requires a **cascade** of centrifuges

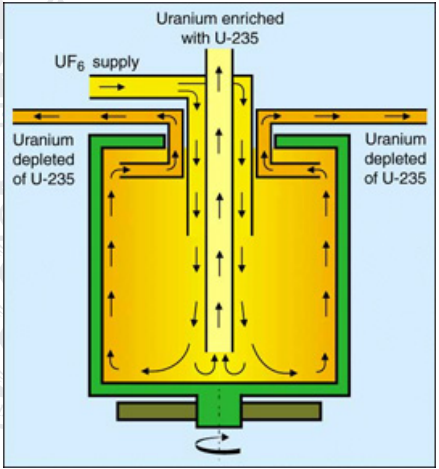
Uranium oxide (U_3O_8), also known as *yellowcake*, converted into uranium hexafluoride (UF_6) gas for enrichment

Source: Cogema, Inc.

Nuclear Capabilities
Uranium Enrichment

Weapons-grade Uranium for use in nuclear weapons (either as fissile weapons or as part of a multi-stage weapon requires much higher enrichment to $\approx$ 90% and is called Highly Enriched Uranium (HEU)

- More difficult to obtain, but has no civilian use except for research quantities
- Requires a **cascade** of centrifuges



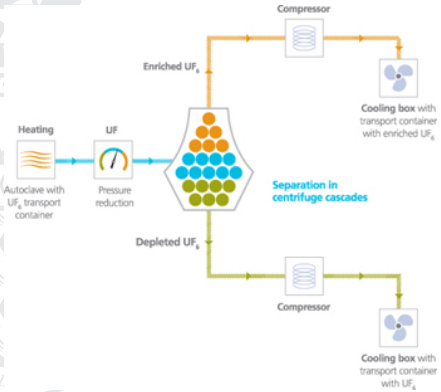
Basic gas centrifuge design

Source: European Nuclear Society

Nuclear Capabilities
Uranium Enrichment

Weapons-grade Uranium for use in nuclear weapons (either as fissile weapons or as part of a multi-stage weapon requires much higher enrichment to ≈ 90% and is called Highly Enriched Uranium (HEU)

- More difficult to obtain, but has no civilian use except for research quantities
- Requires a **cascade** of centrifuges



Centrifuge **cascade**

Source: Urenco

The Stuxnet Attack Vector

Target Environment

Control room in Natanz Uranium enrichment facility (Iran), centrifuge control screens visible

Source: Iran State TV

The Stuxnet Attack Vector
Target Environment

Control room in Natanz facility, detailed view

Source: Iran State TV

Stuxnet in Context (1)

The Stuxnet malware is a case study of a multi-stage malware targeting intermediate systems (Microsoft Windows, Siemens PCS7, WinCC, STEP7) to reach its main objective (Siemens S7 PLCs)

- Note that a true zero-day malware would be much more targeted and therefore not exhibit many of the more “noisy” features seen in Stuxnet
- **Not** targeting too closely does have the important benefit of deniability and leaves an important element of ambiguity

Stuxnet’s delivery mechanism was based on the Microsoft Windows platform, but its primary objective was industrial control systems

- The control systems targeted were highly specific
- A number of *zero-day* exploits were deployed

Stuxnet in Context (2)

Stuxnet is part of a larger family of components used in attacks that served intelligence-gathering purposes sharing a number of components

- The discovery of these inter-relationships was a lengthy investigative process as samples of malware and interactions with targets were not always straightforward to obtain
- The malware also contained a number of sophisticated counter-detection and counter-forensic properties

Stuxnet (and Olympic Games)

Timeline (1)

Like many malware components, Stuxnet (i.e. the platform used as part of Olympic Games) has evolved significantly over time:

August 2007 Malware components later used in Stuxnet and Duqu identified ("*Tilded*") — common practice among malware developers

June 2009 Earliest (public) detection of Stuxnet
Does not yet use zero-day exploit MS10-046 vulnerability or have signed drivers

January 2010 Signed drivers used based on valid certificate of *Realtek Semiconductors*

June 2010 The Belorussian security firm VirusBlokAda first reports **W32.Stuxnet** — this variant of Stuxnet already uses MS10-046
Verisign revokes the compromised Realtek digital certificate

Stuxnet (and Olympic Games)

Timeline (2)

July 2010 A new version of Stuxnet is identified, using a digital certificate of JMicron Technology

August 2010 Microsoft issues MS10-046 security bulletin
The associated patches correct a shell shortcut vulnerability

September 2010 Microsoft issues MS10-061 security bulletin
This patch collection corrects a vulnerability in the printer spooler

September 2010 Iran acknowledges that some of its nuclear facilities including nuclear fuel separation centrifuges have suffered production issues

Stuxnet (and Olympic Games)

Timeline (3)

September 2011 Discovery of Duqu malware built on similar platform, aiming to capture and exfiltrate information from SCADA/DCS infrastructure and manufacturers

May 2012 Discovery of Flame malware, another family member with main payload for intelligence-gathering

July 2012 Discovery of Gauss malware — similar to Flame in scope, but with unknown (encrypted) payload

July 2013 Although involvement of US and Israel in design and deployment were indirectly acknowledged relatively early, documents are leaked to confirm this

February 2015 Kaspersky Labs publishes a report cross-linking components across more than 10 years (2003—2013) forming a platform for espionage and exploitation

Summary

This section provided material on

- Everything you wanted to know about Uranium enrichment but were afraid to ask
- The Iranian facilities for Uranium enrichment
- The Stuxnet and Olympic Games time-line